

# MedDefense Health Systems

Threat Landscape Report

**Author:** Threat Intelligence Analyst | **Date:** [assessment date] | **Companion document to:** Security Posture Assessment (1x00, Task 16)

■ **Navy bold** = report skeleton (fixed structure / section labels — reusable in any report) ■ **Maroon** = filled-in data (specific to this assessment)

## 1. Executive Summary

MedDefense faces a threat landscape defined by one dominant reality: it matches the exact profile ransomware-as-a-service groups build their business model around — a mid-size hospital with valuable patient data, a thin security team and gaps that mirror three regional hospitals already hit in the past 8 months. The single most dangerous threat is a **BlackReef-style ransomware campaign** that encrypts the Electronic Health Record system and every domain-joined system simultaneously, exfiltrating patient data first and destroying the only backup before demanding payment. Our top three recommendations: (1) deploy a functioning detection capability so an intrusion in progress can actually be seen, (2) require a second authentication factor everywhere, including for outside vendors, and (3) close the four gaps that let a single phished email escalate into organization-wide compromise. None of these require replacing existing systems — they require operating the ones MedDefense already has with the discipline this threat landscape demands.

## 2. Scope and Methodology

**Intelligence Sources:** Marcus Webb's threat intelligence collection (CISA healthcare ransomware advisory, HC3 threat actor breakdown, HHS breach portal statistics, a regional hospital ransomware case study, an industry economics article), an 8-report threat actor classification exercise, the BlackReef ransomware-as-a-service profile, 5 insider threat scenarios, 7 social engineering scenarios, 5 vendor risk profiles, and two detailed ATT&CK-mapped attack narratives (1x01 Tasks 0–5, 13).

**Analytical Frameworks Applied:** STRIDE was applied in depth to the EHR system (12 threats across all six categories) and at survey level to PACS, Active Directory and Network Infrastructure (1x01 Tasks 11–12), systematically identifying threat categories rather than relying on ad-hoc brainstorming. MITRE ATT&CK tactics and techniques were mapped step-by-step against two realistic attack narratives, establishing a common vocabulary for describing attack sequences (1x01 Task 13). Kill chain analysis constructed five complete attack sequences from initial access to business impact, each annotated with specific break points where a control could interrupt the chain (1x01 Task 10).

**Connection to 1x00:** This report is the external, adversary-facing counterpart to the Security Posture Assessment. Where 1x00 answered "what does MedDefense have, and where are the gaps," this report answers "who would exploit those gaps, how, and to what end" — and Section 9 shows concretely how threat evidence changes the priority of gaps that 1x00 could only rank by looking inward.

## 3. Healthcare Sector Threat Overview

Why Healthcare Is Targeted:

- 1. **Clinical urgency accelerates payment** — a hospital facing ambulance diversions and cancelled procedures cannot wait out a recovery the way most industries can.
- 2. **Patient data carries outsized black-market value** (\$250–\$1,000 per record vs. \$5–\$50 for a credit card) because it bundles identity-theft and insurance-fraud material that can't simply be cancelled.
- 3. **Legacy technology lowers the cost of entry** — outdated medical device operating systems, EOL servers and flat, unsegmented networks are the norm, not the exception.
- 4. **Cyber insurance and regulatory pressure create built-in payment mechanisms** — most mid-size hospitals carry insurance that often recommends paying, and HIPAA's mandatory breach notification adds a second, independent pressure lever beyond encryption itself.

**Current Trends and Emerging Threats:** Double extortion — exfiltrating data before encrypting it — is now standard practice, occurring in 73% of healthcare ransomware incidents. Exploitation of public-facing applications (VPNs, web portals) has overtaken phishing as the leading initial-access method at 38% of cases, meaning perimeter hardening now matters as much as user training.

**Sector Statistics:** Healthcare was the most-targeted critical infrastructure sector for ransomware in both 2023 and 2024, accounting for 25% of all reported incidents across all 16 sectors. Of over 1,200 reported healthcare breaches in the past 24 months, 43% originated from a compromised network server and 16% from an EHR directly — MedDefense's own two most critical assets sit precisely inside the two largest breach-location categories nationally.

4. MedDefense Threat Actor Profiles

| Actor Type                          | Likelihood  | Priority Ranking |
|-------------------------------------|-------------|------------------|
| Ransomware Groups (Organized Crime) | Critical    | #1               |
| Unskilled / Opportunistic Attacker  | High        | #2               |
| Insider (Negligent)                 | High        | #3               |
| Insider (Malicious)                 | Medium      | —                |
| Nation-State APT                    | Low (today) | —                |
| Hacktivist                          | Low         | —                |

Top 3 Detailed Profiles:

**Actor Profile 1 — Ransomware Groups (Organized Crime):** Operating as Ransomware-as-a-Service platforms (BlackReef being the profiled example), these groups combine developer, affiliate and Initial Access Broker roles into an industrialized criminal supply chain. Medium-to-High sophistication, financially motivated, and explicitly documented as targeting mid-size hospitals like MedDefense as "Tier 1" victims. Their entire attack lifecycle — initial access, reconnaissance, credential theft, exfiltration, backup destruction, encryption — maps step-for-step onto four currently open MedDefense gaps (GAP-014, GAP-002, GAP-017, GAP-003).

**Actor Profile 2 — Unskilled / Opportunistic Attacker:** Automated scanners that target vulnerabilities, not organizations. This is not a projection: this exact actor type has already compromised MedDefense twice through the same unpatched Apache instance on `billing-srv-01` (a ransomware incident, then a cryptominer). Low

sophistication is not a reason for lower priority here — it is a reason for higher urgency, since no targeting decision is required for a third incident.

**Actor Profile 3 — Insider (Negligent):** Employees and contractors solving real workflow problems — a shared login, a workaround script, a personal device — without understanding the risk created. Four of the five insider scenarios analyzed (1x01 Task 3) were negligent rather than malicious, and this actor type has the broadest gap footprint of any category in the entire assessment (GAP-011, GAP-016, GAP-018, GAP-010).

## 5. Attack Surface Analysis

**External Surface:** The Patient Portal, VPN endpoints, O365 email and the Westside Clinic's consumer-grade router form MedDefense's internet-facing perimeter. The Patient Portal already suffered a broken-access-control incident (1x00 Task 1), and no MFA (GAP-014) protects the VPN or email — the two most-used initial-access categories sector-wide.

**Internal Surface:** This is where MedDefense's exposure is most severe. MySQL (**billing-srv-01**) and PostgreSQL (**ehr-db-01**) are both reachable from anywhere on the internal network instead of being restricted to their application servers, and the flat network provides no segmentation between workstations, servers and medical IoT devices at all.

**Human Surface:** Clinical staff (broad, necessary EHR access), reception (the tailgating target), IT staff (elevated privileges, small team), executives (BEC targets) and external contractors (access outliving the HR lifecycle) each carry a distinct exploitation profile, documented across seven realistic social engineering scenarios (1x01 Task 4).

The Internal Surface represents the greatest risk today: the flat network turns every external or human entry point into a direct shortcut to **ehr-db-01**, **NAS-01** and the entire medical IoT fleet at once — the exact pattern that made all three breaches examined in 1x00's Reality Check devastating rather than contained.

## 6. Critical Attack Paths

**The 5 Kill Chains (with break points):**

1. **Phishing to Domain-Wide Ransomware** — break points at the email gateway (Step 1) and at credential-dumping detection before Domain Admin escalation (Step 3).
2. **VPN Credential Compromise to Domain Takeover** — break points at MFA enforcement on the VPN (Step 1) and network segmentation preventing direct DC reachability (Step 3).
3. **Insider Data Exfiltration via Legitimate Access** — break points at DLP/export-volume alerting (Step 3) and USB restriction policy (Step 4).
4. **Unpatched Web Server to Medical Device Exposure** — break points at patching **billing-srv-01**'s Apache instance (Step 1) and network segmentation isolating the medical device subnet (Step 3).
5. **Vendor Compromise to Direct Patient Data Access** — break points at MFA on vendor remote access (Step 1) and restricting **ehr-db-01** to **ehr-srv-01** only (Step 3).

**3 Most Connected Assets:** **ehr-db-01**, Medical IoT (category), and Active Directory — each reachable by 6 of the 8 attack vectors modeled, making them MedDefense's highest-leverage defensive investments.

**3 Most Versatile Vectors:** Phishing/Spear Phishing (reaches all 7 asset categories modeled), VPN Exploit, and Vulnerable Software Exploit (each reaching 6 of 7) — together these three vectors account for the large majority of viable attack paths identified.

## 7. STRIDE Analysis Summary

**EHR Deep Analysis (key findings):** Twelve threats were identified across all six STRIDE categories against `ehr - srv - 01/ehr - db - 01`. Denial of Service represents the greatest risk specifically because of the clinical setting: an EHR outage has already forced a return to paper records once before (1x00 Incident E), and MedDefense's own gaps compound the danger — the EHR server is excluded from antivirus coverage (GAP-005), no detection exists to catch an attack in progress (GAP-002), and the one recovery mechanism (backup) is itself unprotected (GAP-003).

**PACS, AD and Network Surface Analysis (top threats per system):** PACS's top threat is also Denial of Service — it is the only Critical asset explicitly excluded from nightly backup, combined with an unpatchable Windows XP imaging workstation. Active Directory's top threat is Elevation of Privilege, since no privilege tiering separates routine admin work from full domain authority (GAP-017). Network Infrastructure's top threat is again Denial of Service, since the FortiGate is MedDefense's sole perimeter and routing chokepoint with no redundancy.

## 8. Threat Scenarios

**Scenario 1 (summary) — BlackReef Ransomware Campaign:** A phished IT Director's workstation leads, within days, to Domain Admin compromise, exfiltration of the patient database, backup destruction, and organization-wide encryption. Business impact: clinical operations halted, mandatory breach notification for 50,000+ patients, and a documented ransom range of \$1–3M plus recovery costs.

**Scenario 2 (summary) — Insider Data Exfiltration:** A billing employee facing termination exports thousands of patient records over two weeks using entirely legitimate access, then re-enters the network days after her last day using credentials that were never deactivated. Business impact: mandatory notification for thousands of records, discovered — if at all — far later than an external attack.

**Scenario 3 (summary) — MedTech Supply Chain Compromise:** A compromised vendor credential provides a direct, unmitigated path to the patient database with no additional exploitation required. Business impact: a breach MedDefense's own controls cannot detect, since the access appears fully authorized.

*Full detail: see 1x01 Task 14 appendix.*

## 9. Gap-Threat Correlation

**How Threats Recalibrated Gap Priorities:** Cross-referencing all 19 gaps from 1x00 against the actors, kill chains and scenarios built in this project moved five gaps upward (GAP-001, GAP-008, GAP-012, GAP-016, GAP-018 — all to Critical or High) and one downward (GAP-006, from Critical to High), because threat evidence showed physical access is not a preferred vector for any of the six profiled actor types, while credential- and network-based gaps dominate every real attack path modeled.

**The Critical Three:** GAP-002 (no detection capability, present in 7 of 8 possible kill-chain/scenario appearances), GAP-001 (EHR reachable network-wide, present in all 3 scenarios), and GAP-014 (no MFA, tied for the most kill-chain appearances). Closing these three would disrupt every kill chain in this report except the medical-device path.

**The Surprise:** GAP-012 (flat network as pivot point) was the only Medium-rated gap in 1x00's original analysis, on the reasoning that partial controls reduced the risk. Threat analysis overturned that: it is a named step in the #1-priority actor's kill chain and top scenario, and none of the partial controls that justified "Medium" meaningfully impede that specific actor's lateral movement.

## 10. Prioritized Recommendations

### Top 5 Threats with Recommended Actions:

| Rank | Threat                                                    | Recommended Action                                                 |
|------|-----------------------------------------------------------|--------------------------------------------------------------------|
| 1    | BlackReef-style ransomware campaign                       | Deploy SIEM/EDR alerting on pre-encryption indicators — Short-term |
| 2    | Opportunistic exploitation of <code>billing-srv-01</code> | Patch Apache / upgrade Ubuntu 18.04 — Quick Win                    |
| 3    | Insider data exfiltration via legitimate access           | Deploy DLP/export-volume alerting on the EHR — Short-term          |
| 4    | Vendor/supply chain compromise (MedTech)                  | Enforce MFA on all vendor remote access — Quick Win                |
| 5    | Medical IoT compromise via flat network                   | VLAN segmentation of the medical device subnet — Long-term         |

**Strategic 2-Initiative Recommendation:** If only two initiatives can be funded this quarter, they should be a functioning detection capability (closing GAP-002, the single most-cited gap in this entire report) and organization-wide MFA enforcement including vendor access (closing GAP-014). Together these two touch four of the five Top 5 threats without requiring the network redesign that fully addressing Rank 5 would need.

**Connection to Next Phase (1x02 — Vulnerability Assessment):** This report has established who threatens MedDefense and how they would most likely proceed — kill chains, technical vectors and threat actor priorities. It has not established exactly where, at a granular technical level, each specific vulnerability lives or how it should be scored and remediated. That is the explicit scope of the next project: 1x02 will take the attack surface and technical vectors mapped here and conduct the hands-on vulnerability assessment that turns "this category of weakness enables this category of attack" into a prioritized, scored remediation backlog.

## Threat Briefing — One-Page Executive Version

MedDefense matches, almost exactly, the profile ransomware-as-a-service crews build their business around: a mid-size hospital, valuable patient data, a thin security team, and gaps that mirror three regional hospitals already hit in the past 8 months.

**Top Threat:** A BlackReef-style ransomware campaign that steals patient data, destroys our only backup, and then encrypts every domain-joined system at once — before demanding payment. This is not a hypothetical; it follows the same pattern already used against three regional hospitals.

### Priority Actions:

1. Deploy a functioning detection capability so an intrusion in progress can actually be seen, instead of found by accident weeks later.
2. Require a second authentication factor everywhere, including for outside vendors — closing our most-cited weakness across every attack path modeled.
3. Close the four gaps that let a single phished email escalate into organization-wide compromise.

**Business Case:** None of these require replacing a single system we already own — they require operating what we have with the discipline this threat landscape demands. Closing just two of them (detection and MFA) would disrupt four of our top five modeled threats.

**Closing:** We now know who is most likely to target us and exactly how they would proceed. The next phase turns that knowledge into a scored, prioritized technical remediation backlog.